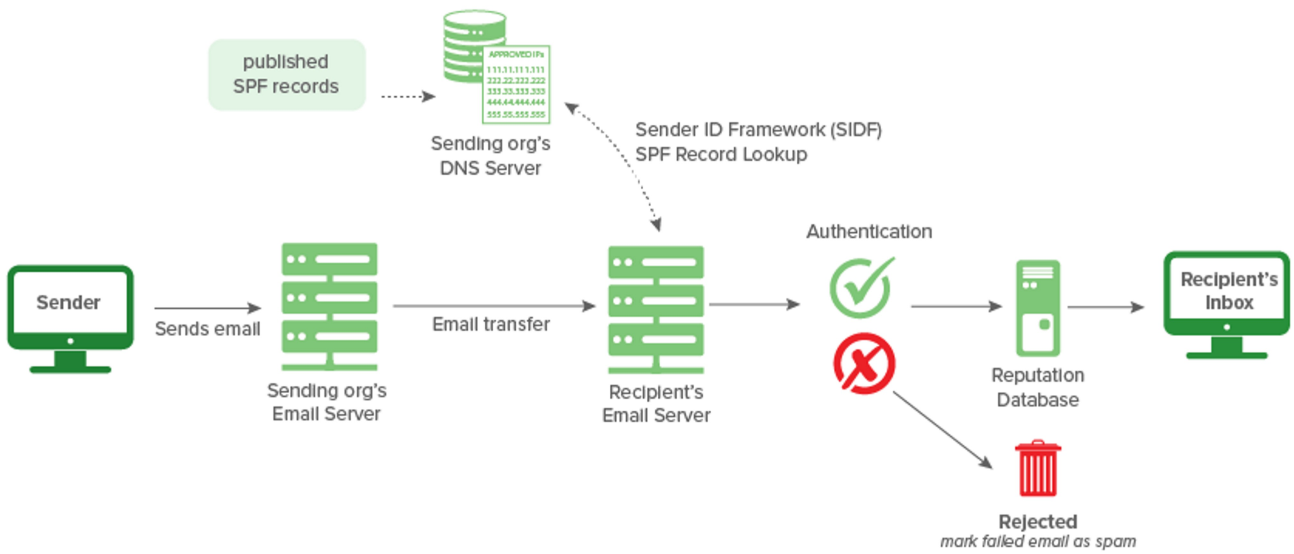
Tuesday, August 19, 2025 9:51 PM



1️⃣ SPF (Sender Policy Framework)

- **What it does:**
  SPF checks **"Is this mail server allowed to send emails for this domain?"**
- **How it works:**
  1. Domain owner publishes an **SPF record** in DNS (like a list of authorized servers).
     Example:

     Codingseekho.com → v=spf1 include:_spf.google.com -all

  2. When an email is received, the recipient's server looks at the SPF record.
  3. If the sending server's IP is in the list → **Pass** ✅
     Otherwise → **Fail > SPAM** ❌
- **Analogy:**
  Imagine a **guest list** at a party. If your name is not on the list → you can't enter.

Typical results in header:

- ✅ **spf=pass → Email came from an allowed server.**
- ❌ **spf=fail → Email was sent from a server NOT authorized.**
- ⚠️ **spf=softfail → Email not authorized, but allowed (may be spam).**
- ⚠️ **spf=neutral → No decision (treated as fail in many systems).**
- ❓ **spf=none → Domain has no SPF record set.**

Manually Verify SPF Record (Optional)

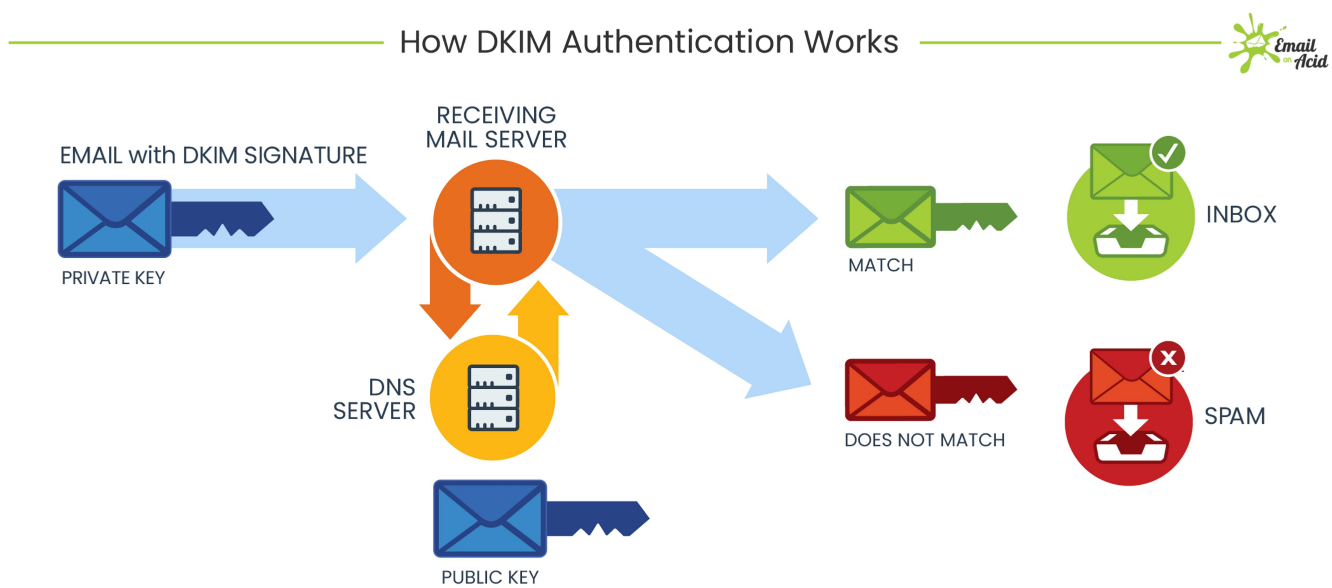
- **Run a DNS query to see SPF record for the domain:**

👉 **Command line:**

nslookup -type=txt example.com
You'll get something like:

"v=spf1 include:_spf.google.com ~all"

- **This means only Google's servers can send mail for @example.com.**
- **If the spam email came from another IP → spoofed.**

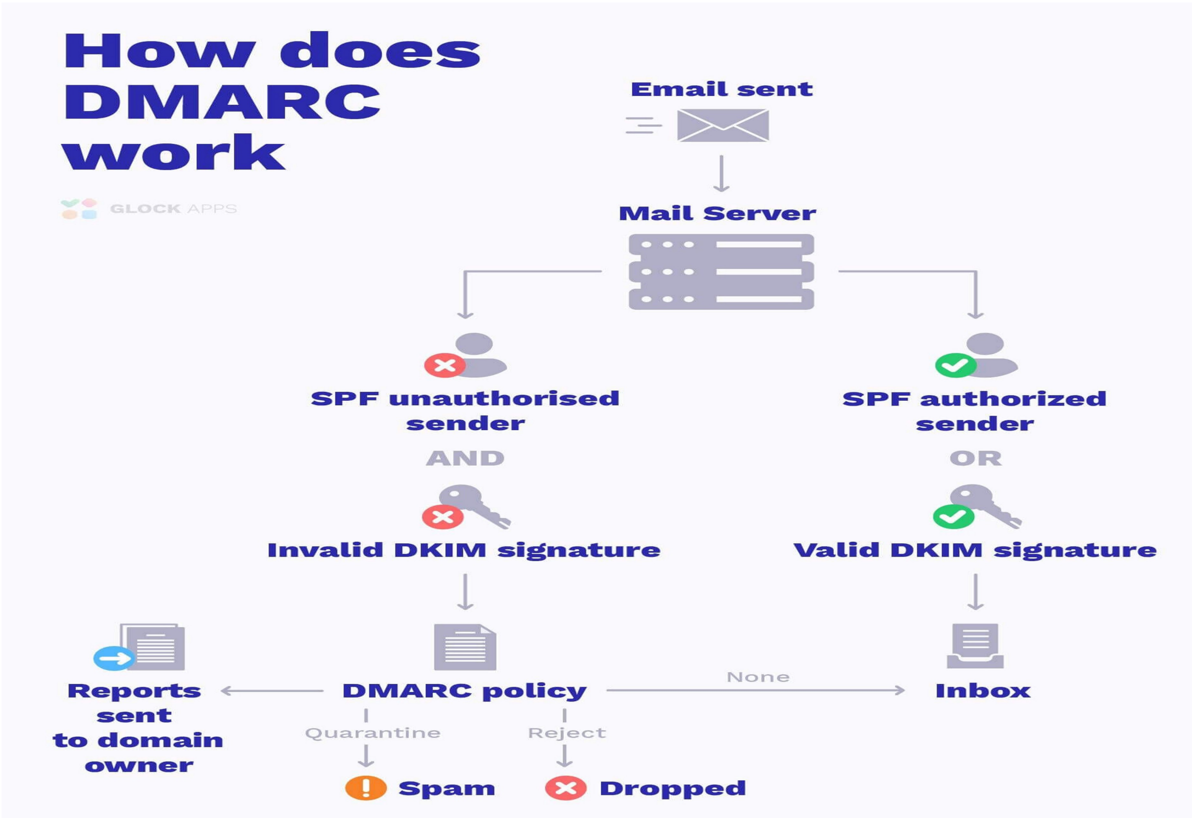


DKIM (DomainKeys Identified Mail)

- **What it does:**
  DKIM ensures the **email content has not been altered** during transmission and verifies it was sent by the claimed domain.
- **How it works:**
  1. Sending server **signs the email** with a private cryptographic key.
  2. The recipient's server checks the signature using the public key published in DNS.
  3. If the signature matches → email is authentic and unmodified.
- **Analogy:**
  It's like a **wax seal on a letter**. If the seal is intact → you know it wasn't tampered with.

Typical results:

- ✅ **dkim=pass → Signature is valid → Sender domain authorized & content not changed.**
- ❌ **dkim=fail → Signature invalid → Email may be spoofed or altered.**
- ⚠️ **dkim=neutral / none → No DKIM record found**



DMARC (Domain-based Message Authentication, Reporting & Conformance)

- **What it does:**
  DMARC builds on SPF + DKIM.
  It tells the receiving server:
  - What to do if SPF/DKIM fail (none, quarantine, reject).
  - Sends reports back to domain owners about spoofing attempts.
- **How it works:**
  1. Domain owner publishes a DMARC record in DNS. Example:

     _dmarc.example.com → v=DMARC1; p=reject; rua=mailto:dmarc-reports@example.com

  2. If an email fails SPF or DKIM → the recipient checks the DMARC policy.
     - **p=none** → just monitor
     - **p=quarantine** → mark as spam
     - **p=reject** → block the email

- **Analogy:**

DMARC is like a **police officer at the gate**.
If SPF/DKIM checks fail, the officer decides: let them in, put them in holding, or kick them out.